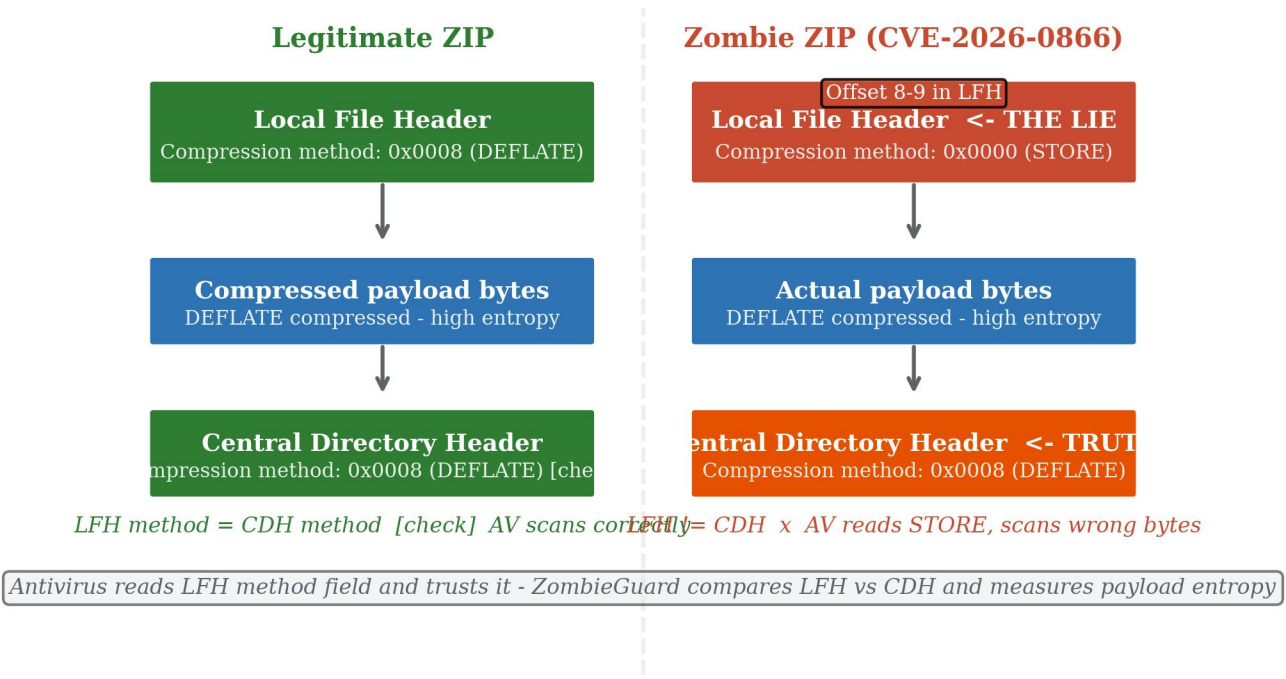
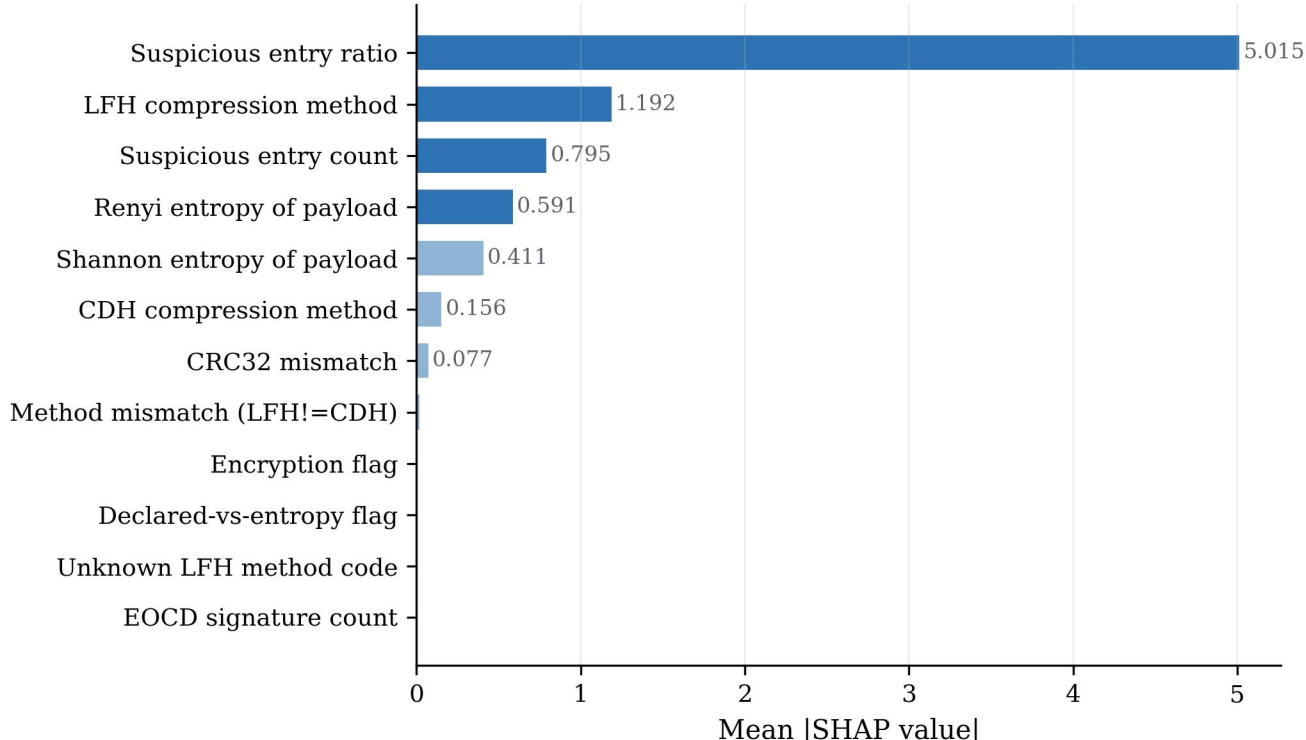



Figure 1. Archive header evasion in CVE-2026-0866 (Zombie ZIP): the Local File Header declares STORE while the Central Directory and actual payload bytes declare DEFLATE.

| ID | Variant Name | LFH Method | CDH Method | Payload | Primary Signal |
|---|---|---|---|---|---|
| A | Classic Zombie ZIP | STORE (0) | DEFLATE (8) | Compressed | method_mismatch |
| B | Method-only mismatch | DEFLATE (8) | STORE (0) | Stored | method_mismatch |
| C | Gootloader concatenation | DEFLATE (8) | DEFLATE (8) | Compressed | eocd_count > 1 |
| D | Multi-file decoy | STORE (0) | DEFLATE (8) | Compressed | suspicious_entry_ratio |
| E | CRC32 mismatch | DEFLATE (8) | DEFLATE (8) | Compressed | any_crc_mismatch |
| F | Extra field noise | STORE (0) | DEFLATE (8) | Compressed | Structural combination |
| G | High compression mismatch | STORE (0) | DEFLATE (8) | Compressed | entropy gap (max) |
| H | Size field mismatch | STORE (0) | DEFLATE (8) | Compressed | Size inconsistency |

*Table 2. Taxonomy of eight archive header evasion variants implemented in ZombieGuard. Each variant targets a different structural inconsistency field in the ZIP Local File Header (LFH) or Central Directory Header (CDH).*

Figure 3. SHAP feature importance - mean absolute SHAP values across all test samples confirming structural attack signals drive detection.



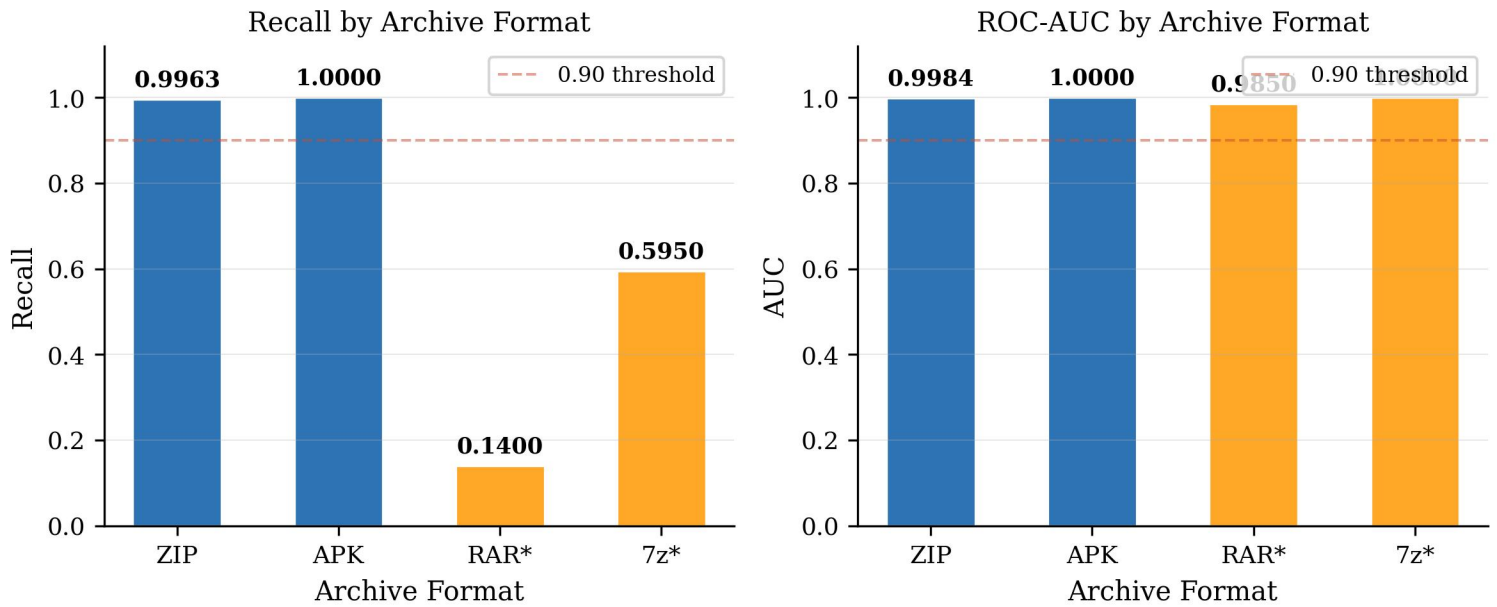
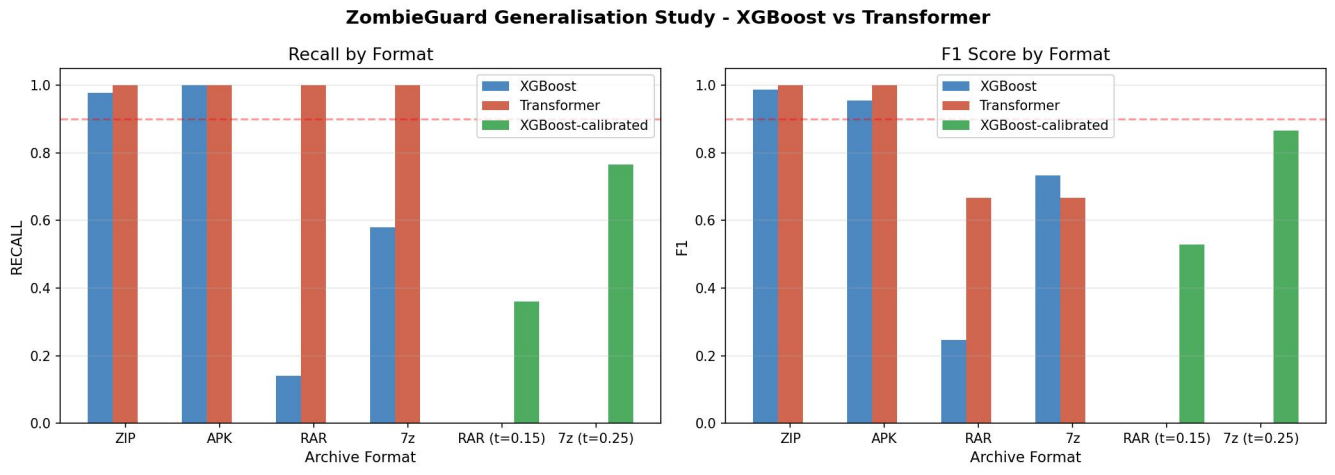
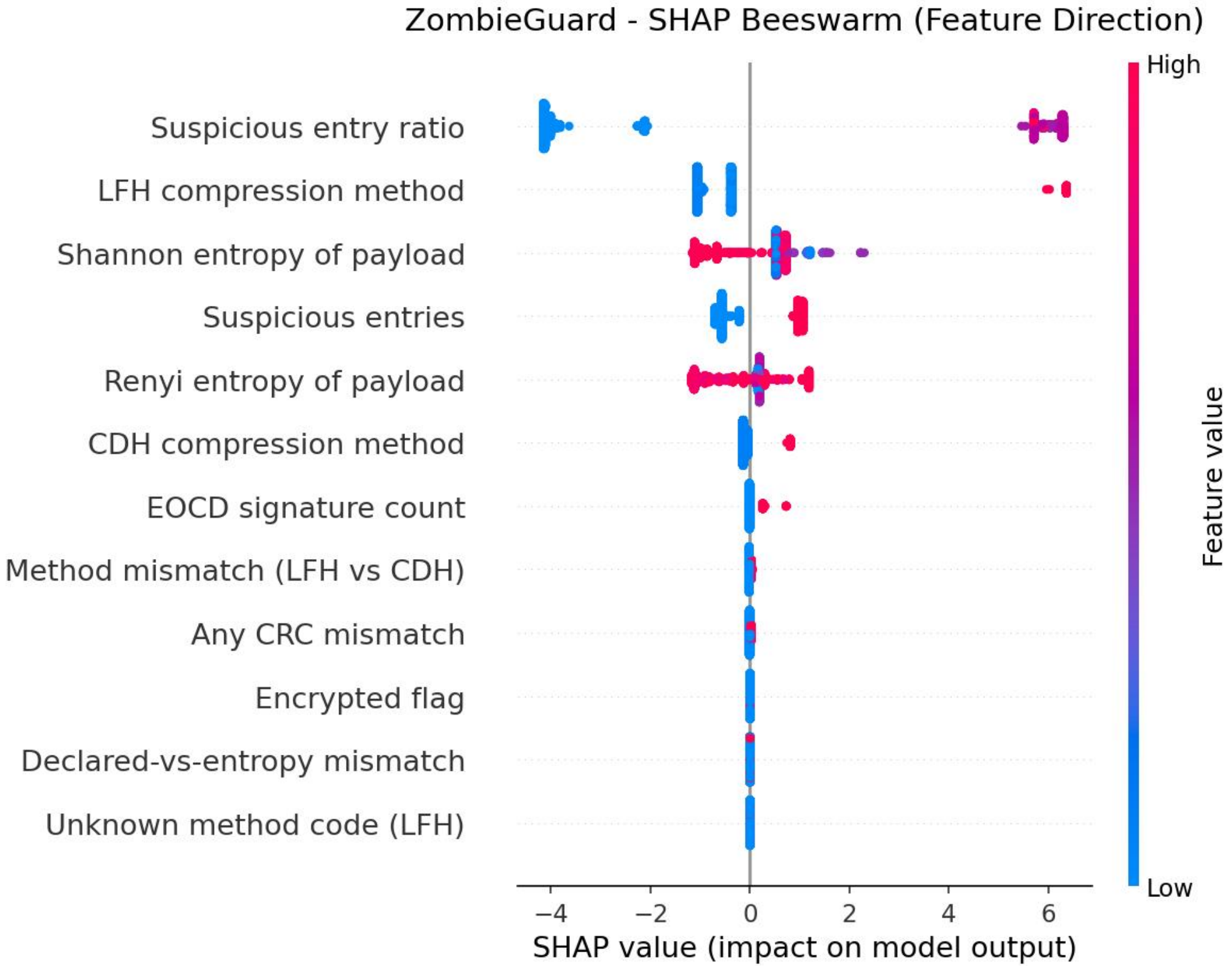
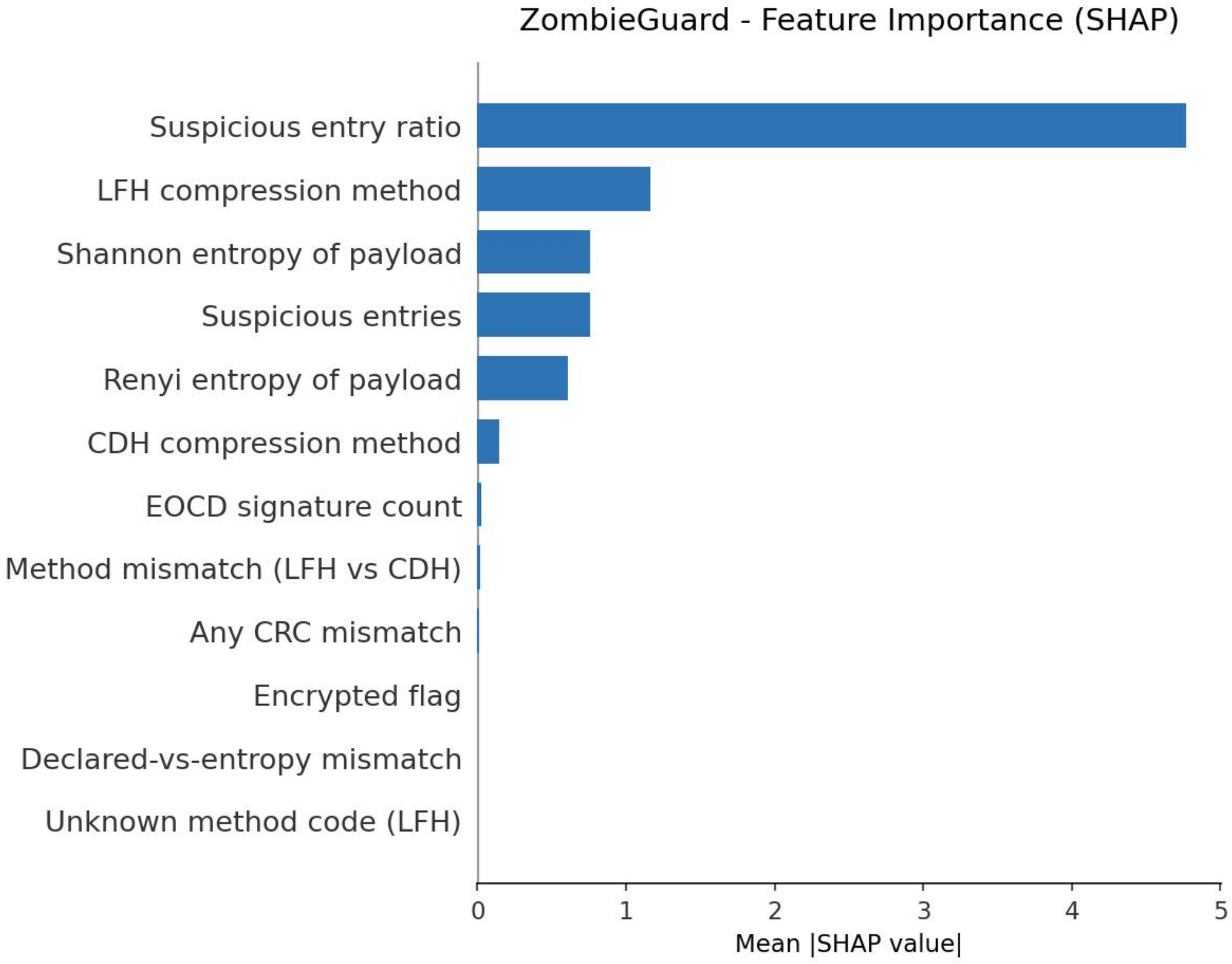
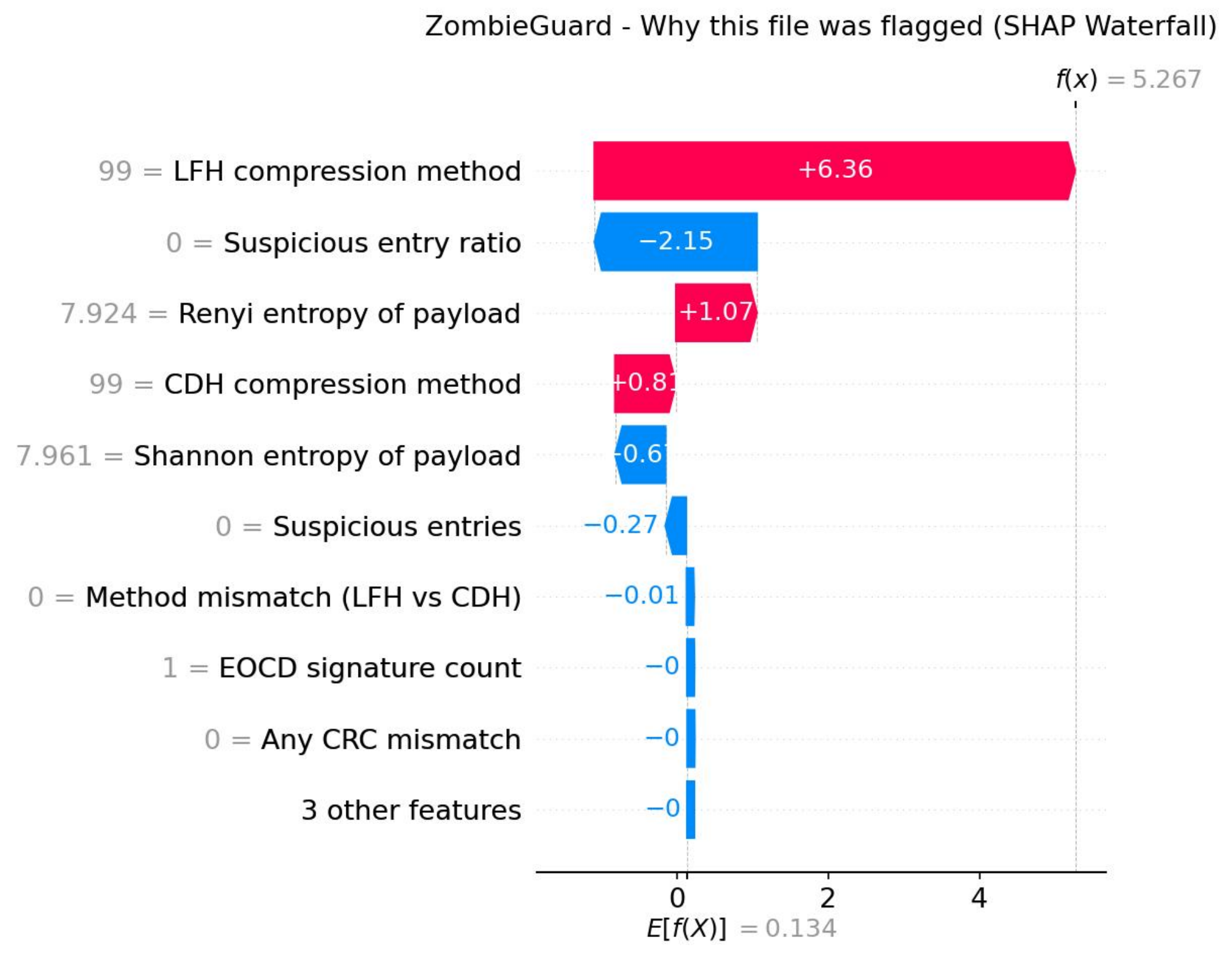



Figure 4. Cross-format generalization of Zombie Guard. * The XGBoost model achieves perfect transfer (ZIP-based format). RAR/7z show strong AUC but low recall - threshold miscalibration under distribution shift.


ZombieGuard Generalisation Study - XGBoost vs Transformer
Recall by Format
RECALL
Archive Format
XGBoost
Transformer
XGBoost-calibrated
ZIP
APK
RAR
7z
RAR (t=0.15)
7z (t=0.25)
F1 Score by Format
F1
Archive Format
XGBoost
Transformer
XGBoost-calibrated
ZIP
APK
RAR
7z
RAR (t=0.15)
7z (t=0.25)


ZombieGuard - SHAP Beeswarm (Feature Direction)
Suspicious entry ratio
LFH compression method
Shannon entropy of payload
Suspicious entries
Renyi entropy of payload
CDH compression method
EOCD signature count
Method mismatch (LFH vs CDH)
Any CRC mismatch
Encrypted flag
Declared-vs-entropy mismatch
Unknown method code (LFH)
−4
−2
0
2
4
6
SHAP value (impact on model output)
High
Feature value
Low


ZombieGuard - Feature Importance (SHAP)
Suspicious entry ratio
LFH compression method
Shannon entropy of payload
Suspicious entries
Renyi entropy of payload
CDH compression method
EOCD signature count
Method mismatch (LFH vs CDH)
Any CRC mismatch
Encrypted flag
Declared-vs-entropy mismatch
Unknown method code (LFH)
0
1
2
3
4
5
Mean |SHAP value|


ZombieGuard - Why this file was flagged (SHAP Waterfall)
f(x) = 5.267
99 = LFH compression method
+6.36
0 = Suspicious entry ratio
−2.15
7.924 = Renyi entropy of payload
+1.07
99 = CDH compression method
+0.81
7.961 = Shannon entropy of payload
−0.61
0 = Suspicious entries
−0.27
0 = Method mismatch (LFH vs CDH)
−0.01
1 = EOCD signature count
−0
0 = Any CRC mismatch
−0
3 other features
−0
0
2
4
E[f(X)] = 0.134

| Component | Samples | Description | Source | Role |
|---|---|---|---|---|
| **Synthetic - malicious** | 1,348 | 8 structural variants | Generator | Training |
| **Synthetic - benign** | 1,445 | PyPI package wheels | PyPI API | Training |
| **Hard negative benign** | 200 | Quirky but clean ZIPs | Generator | Training |
| **Real-world validation** | 1,366 | 18 malware families | MalwareBazaar | Validation only |
| **Hard test set** | 271 | 10 real + 22 synthetic | Mixed | Evaluation |
| **Total (excl. hard test)** | 2,993 | - | Mixed | Training |

*Table 3. Dataset composition. Real-world validation samples are used exclusively for evaluation - not training.*

| Signal Type | Count | Share of 165 | ZombieGuard Feature |
|---|---|---|---|
| Gootloader EOCD chaining (EOCD > 1) | 66 | 85.7% | eocd_count |
| High entropy anomaly (new variant) | 7 | 9.1% | data_entropy_shannon |
| Undefined LFH method code (method=99) | 1 | 1.3% | lf_unknown_method |
| True CVE-2026-0866 LFH/CDH mismatch | 1 | 1.3% | method_mismatch |
| **Total detected (evasion)** | **77** | **46.7%** | **-** |
| Non-evasion ZIP malware (out of scope) | 88 | 53.3% | - |

*Table 4. Real-world signal breakdown from 165 targeted MalwareBazaar samples. ZombieGuard detected 77 files (46.7%) with zero false positives.*

| Format | Model | Recall | Precision | F1 | ROC-AUC | Notes |
|---|---|---|---|---|---|---|
| ZIP | XGBoost | 0.9963 | 1.0000 | 0.9981 | **0.9984** | Primary format |
| APK | XGBoost | 1.0000 | 1.0000 | 1.0000 | **1.0000** | ZIP-based, full transfer |
| RAR | XGBoost | 0.1400 | 0.9850 | - | **0.9850** | Low recall, AUC intact |
| 7z | XGBoost | 0.5950 | 1.0000 | - | **1.0000** | Threshold miscalibration |
| ZIP | Transformer | 1.0000 | 1.0000 | 1.0000 | **1.0000** | Memorised byte patterns |
| APK | Transformer | 1.0000 | 1.0000 | 1.0000 | **1.0000** | ZIP-based, transfers |
| RAR | Transformer | 1.0000 | 0.2031 | - | **0.2031** | Flagged all as malicious |
| 7z | Transformer | 1.0000 | 0.1680 | - | **0.1680** | Flagged all as malicious |

*Table 5. Cross-format generalisation results. Green = strong performance. Red = model failure (AUC < 0.5 indicates worse than random - Transformer flagged all non-ZIP files as malicious).*